

Use IAM securely

This page recommends security best practices that you should keep in mind when using IAM.

This page is designed for users who are proficient with IAM. If you are just starting out with IAM, these instructions will not teach you how to use it; instead, new users should start with the [IAM Quickstart](/iam/docs/grant-role-console) (/iam/docs/grant-role-console).

Least privilege

- ☐ Basic roles include thousands of permissions across all Google Cloud services. In production environments, do not grant basic roles unless there is no alternative. Instead, grant the most limited [predefined roles](/iam/docs/roles-permissions) (/iam/docs/roles-permissions) or [custom roles](/iam/docs/understanding-custom-roles) (/iam/docs/understanding-custom-roles) that meet your needs.

If you need to replace a basic role, you can use [role recommendations](/iam/docs/recommender-overview) (/iam/docs/recommender-overview) to determine which roles to grant instead. You can also use the [Policy Simulator](/iam/docs/understanding-simulator) (/iam/docs/understanding-simulator) to ensure that changing the role won't affect the principal's access.

It might be appropriate to grant basic roles when you want to grant broader permissions for a project. For example, you can grant basic roles for use in test or development environments.

-
- ☐ Treat each component of your application as a separate trust boundary. If you have multiple services that require different permissions, [create a separate service account](/iam/docs/managing-service-accounts) (/iam/docs/managing-service-accounts) for each of the services, then grant only the required permissions to each service account.
-
- ☐ Remember that the allow policies for child resources inherit from the allow policies for their parent resources. For example, if the allow policy for a project grants a user the ability to administer Compute Engine virtual machine (VM) instances, then the user can administer any Compute Engine VM in that project, regardless of the allow policy you set on each VM.
-
- ☐ Grant roles at the smallest scope needed. For example, if a user only needs access to publish Pub/Sub topics, grant the [Publisher](/pubsub/access_control#tbl_roles) (/pubsub/access_control#tbl_roles) role to the user for that topic.
-
- ☐ Specify which principals can [act as service accounts](/iam/docs/service-account-permissions#user-role) (/iam/docs/service-account-permissions#user-role). Users who are granted the Service Account User role for a service account can access all the resources to which the service account has access. Therefore, be cautious when granting the Service Account User role to a user.
-

☐ Specify who has access to create and manage service accounts in your project.

☐ Granting the [Project IAM Admin and Folder IAM Admin](/iam/docs/roles-permissions/resource-manager) (/iam/docs/roles-permissions/resource-manager) predefined roles will allow access to modify allow policies without also allowing direct read, write, and administrative access to all resources.

Granting the [Owner](/iam/docs/roles-overview#basic) (/iam/docs/roles-overview#basic) (**roles/owner**) role to a principal will allow them to access and modify almost all resources, including modifying allow policies. This amount of privilege is potentially risky. Grant the Owner role only when (nearly) universal access is required.

☐ Use [conditional role bindings](/iam/docs/configuring-temporary-access) (/iam/docs/configuring-temporary-access) to let access expire automatically, and consider granting [temporary elevated access](/iam/docs/temporary-elevated-access). (/iam/docs/temporary-elevated-access)

Service accounts

☐ [Adopt best practices for working with service accounts](/iam/docs/best-practices-service-accounts) (/iam/docs/best-practices-service-accounts). Ensure that service accounts have limited privileges, and protect against potential security threats.

☐ Do not delete service accounts that are in use by running instances. This could result in all or parts of your application to fail if you have not transitioned to using an alternative service account first.

☐ Use the display name of a service account to keep track of what the service account is used for and what permissions it needs.

Service account keys

-
- ☐ **Avoid using service account keys if another option is available.** Service account keys are a security risk if not managed correctly. You should [choose a more secure alternative to service account keys](#) (/docs/authentication#auth-decision-tree) whenever possible. If you must authenticate with a service account key, you are responsible for the security of the private key and for other operations described by [Best practices for managing service account keys](#) (/iam/docs/best-practices-for-managing-service-account-keys). If you are prevented from creating a service account key, service account key creation might be disabled for your organization. For more information, see [Managing secure-by-default organization resources](#) (/resource-manager/docs/secure-by-default-organizations).

If you acquired the service account key from an external source, you must validate it before use. For more information, see [Security requirements for externally sourced credentials](#) (/docs/authentication/external/externally-sourced-credentials).

-
- ☐ Rotate your service account keys using the [IAM service account API](#) (/iam/reference/rest/v1). You can rotate a key by creating a new key, switching applications to use the new key, disabling the old key, and then deleting the old key when you are sure that it is no longer needed.
-
- ☐ [Implement processes](#) (/iam/docs/best-practices-for-managing-service-account-keys) to manage user-managed service account keys.
-
- ☐ Be careful not to confuse encryption keys with service account keys. Encryption keys are typically used to encrypt data and service account keys are used for secure access to Google Cloud APIs.
-
- ☐ Don't check in the service account keys into the source code or leave them in the Downloads directory.
-

Auditing

-
- ☐ Use logs from [Cloud Audit Logs](#) (/logging/docs/audit) to regularly audit changes to your allow policy.
-
- ☐ [Export audit logs](#) (/logging/docs/export) to Cloud Storage to store your logs for long periods of time.
-
- ☐ Audit who has the ability to change your allow policies on your projects.
-
- ☐ Manage access to logs using [Logging roles](#) (/logging/docs/access-control).
-
- ☐ Apply the same access policies to the Google Cloud resource that you use to route logs as applied to the Logs Explorer.
-
- ☐ Use logs from Cloud Audit Logs to regularly audit access to service account keys.
-

Policy management

- ☐ If a principal needs access to all projects in your organization, grant roles to the principal at the organization level (</resource-manager/docs/access-control-org>).
- ☐ Grant roles to groups instead of individual users when possible. It is easier to update the members of a group than to update the principals in your allow policies.

Except as otherwise noted, the content of this page is licensed under the [Creative Commons Attribution 4.0 License](https://creativecommons.org/licenses/by/4.0/) (<https://creativecommons.org/licenses/by/4.0/>), and code samples are licensed under the [Apache 2.0 License](https://www.apache.org/licenses/LICENSE-2.0) (<https://www.apache.org/licenses/LICENSE-2.0>). For details, see the [Google Developers Site Policies](https://developers.google.com/site-policies) (<https://developers.google.com/site-policies>). Java is a registered trademark of Oracle and/or its affiliates.

Last updated 2026-09-10 UTC.